

Plataforma de Cursos Online

Stripe + Privacy by Design

PLANO DE EXECUCAO | SPRINTS | MARCOS | DATAS

INICIO DO PROJETO	GO-LIVE PREVISTO	POS-LANCAMENTO	TIMELINE TOTAL
09 Jun 2026	14 Nov 2026	10 Nov 2026 -> 12 Dez 2026	26 semanas / aprox. 6

Autor: Miguel Ribas Berlese | NexMint Labs | Classificacao: Confidencial
Gerado em: 09 Jun 2026 | Baseado em PDF-ARCH-001 v6.0 (Marco 2026)

RESUMO EXECUTIVO

Visao geral, premissas e estrutura de fases

Este documento define o plano de execucao para a Plataforma de Cursos Online com Stripe + Privacy by Design. O sistema resolve tres problemas criticos de produtores de cursos premium (R\$ 5k-50k/ano): duplicacao de contas, ausencia de anonimato e compartilhamento de acesso. O cronograma foi definido com estimativas realistas para 1-2 desenvolvedores TypeScript senior, corrigindo a premissa original de 12 semanas para 22 semanas de MVP (+ 4 semanas de pos-lancamento = 26 semanas total).

Premissas do Planejamento

- Equipe: 1-2 desenvolvedores TypeScript senior (NestJS + Next.js)
- Sprint de 2 semanas. Velocidade estimada: 6-8 entregaveis por sprint.
- Stack: Next.js 14 - NestJS - PostgreSQL 16 - Redis 7 - Stripe - Vercel - Railway
- Decisao Mux vs Bunny Stream: OBRIGATORIA no Sprint 1 (bloqueia Sprint 6)
- Sessoes: opaque token stateful (NAO JWT) - elimina paradoxo arquitetural do v6.0
- device_token: httpOnly cookie SameSite=Strict (NAO localStorage) - elimina XSS
- Payback: estimativa honesta de 12-18 meses conservador (nao 3 meses)
- LGPD: compliance documentado no Sprint 10, antes do go-live

Estrutura de Fases

Fase	Nome	Sprints	Inicio	Fim
1	Validacao & Setup	S1-S2	09 Jun 2026	27 Jun 2026
2	Identidade & Pagamentos	S3-S6	23 Jun 2026	25 Jul 2026
3	Autenticacao Progressiva	S7-S10	21 Jul 2026	22 Ago 2026
4	Acesso a Conteudo	S11-S14	18 Ago 2026	19 Set 2026
5	Admin & Migracao	S15-S18	15 Set 2026	17 Out 2026
6	Hardening & Go-Live	S19-S22	13 Out 2026	14 Nov 2026
7	Pos-Lancamento	S23-S26	10 Nov 2026	12 Dez 2026

S01 Validacao & Setup

09 Jun 2026 -> 27 Jun 2026

! ATENCAO: Mux vs Bunny Stream DEVE ser decidido aqui. Sem isso o Sprint 6 nao começa.

- Decisao: Mux vs Bunny Stream (OBRIGATORIO - bloqueia Sprint 6)
- Ambientes DEV / Staging / Prod criados e documentados
- Stripe test account + webhooks locais configurados (Stripe CLI)
- Repositorio + CI/CD base (GitHub Actions: lint, build, test)
- Docker Compose local: PostgreSQL 16 + Redis 7
- Decisao arquitetural documentada: opaque token stateful (nao JWT)
- Decisao documentada: device_token via httpOnly cookie (nao localStorage)

FASE 2 - Identidade & Pagamentos

Semanas 3-6 | 23 Jun 2026 -> 11 Jul 2026

S02 Sistema de Identidade - Core

23 Jun 2026 -> 11 Jul 2026

- Tabelas: users, user_emails, payments, enrollments (schema v6.0)
- Geracao de user_token (UUID v4 criptograficamente seguro, VARCHAR 64)
- Os 4 sinais de vinculacao: (1) email (2) stripe_customer_id (3) card_last4+BIN (4) device_token
- Logica dos 3 estados: VINCULAR / CRIAR / REVISAR (campo needs_review)
- Testes unitarios da logica de vinculacao - cobertura $\geq$ 80% neste modulo
- Tratamento de conflitos: merge_candidate_id preenchido quando needs_review=true

S03 Stripe Checkout & Webhooks

07 Jul 2026 -> 25 Jul 2026

- Checkout Session via Stripe Checkout hospedado (zero dado pessoal no banco)
- Webhook: checkout.session.completed com idempotencia via tabela stripe_events
- Processamento atomico: INSERT stripe_events + criar enrollment em transacao unica
- Dead-letter queue para falhas persistentes de webhook (BullMQ + Redis)
- Alerta automatico para eventos nao processados apos 3 tentativas
- Testes de idempotencia: mesmo evento Stripe enviado 10x = 1 enrollment criado

FASE 3 - Autenticacao Progressiva

Semanas 7-10 | 21 Jul 2026 -> 08 Ago 2026

S04 Autenticacao PIN + Apelido

21 Jul 2026 -> 08 Ago 2026

- PIN 6 digitos com bcrypt (custo 12) - nunca armazenar PIN em plaintext
- Anti-enumeracao: resposta identica para alias inexistente e PIN errado
- Rate limit por alias: 5 erros -> bloqueio 30min, 15 erros -> PIN invalidado
- Rate limit por IP via Redis: 20 tentativas/hora (chave login_attempts:{ip} TTL 1h)
- Tempo de resposta constante: bcrypt contra hash dummy quando alias nao existe
- Testes de seguranca: tentativas de enumeracao, brute-force por IP, bloqueio

S05 Sessao & E-mail Opcional

04 Ago 2026 -> 22 Ago 2026

! ATENCAO: device_token DEVE usar httpOnly cookie. localStorage e vulneravel a XSS.

- Opaque token stateful (NaO JWT) - VARCHAR 128 aleatorio criptograficamente seguro
- Tabela sessions com auth_level: token / pin / full
- Sessao unica concorrente: nova sessao encerra a anterior automaticamente
- E-mail opcional com magic link via Resend (validade 15 minutos, uso unico)
- device_token via httpOnly cookie + SameSite=Strict + Secure (NAO localStorage)
- Matriz de permissoes por auth_level implementada como Guard no NestJS
- Testes: elevacao de nivel, sessao concorrente, expiracao, revogacao

S06 Player de Video & Progresso

18 Ago 2026 -> 05 Set 2026

- Integracao com plataforma escolhida no Sprint 1 (Mux ou Bunny Stream)
- Signed URLs temporarias geradas on-demand (TTL 4 horas)
- Progresso por aula salvo automaticamente (debounce 10s)
- Acesso condicional: somente enrollments com status active ou grace_period
- URL nao reutilizavel fora do device da sessao atual
- Testes: acesso com enrollment expirado bloqueado, URL expirada rejeitada

S07 Anti-Sharing Completo

01 Set 2026 -> 19 Set 2026

- Limite de 2 devices simultaneos por usuario (campo devices_limit)
- 3o device: bloqueio com mensagem clara + link para gerenciar devices
- Sessao unica: nova sessao em device diferente encerra a sessao anterior
- Fingerprint de User-Agent como campo de backup (ua_fingerprint)
- Fluxo de recuperacao documentado: usuario que perdeu cookie (device_token)
- Testes: 2 devices ok, 3o bloqueado, troca de device, recuperacao de acesso

S08 Painel Admin

15 Set 2026 -> 03 Out 2026

- Listagem de compradores: user_token, alias, status, auth_level, total_spent
- Busca por user_token e alias
- Gerenciamento de devices por usuario (ver, revogar, trustar)
- Fila de aprovacao: pending_review para usuarios high_risk
- Exportacao CSV de base de compradores
- Autenticacao admin separada com auth_level=full obrigatorio

S09 Migracao de Base Existente

29 Set 2026 -> 17 Out 2026

- Tabela legacy_payments: historico financeiro pre-migracao
- Geracao de claim codes unicos (UUID) por comprador existente
- Fluxo de resgate: claim code -> cria ou vincula user_token
- Validade dos claim codes configuravel (padrao: 90 dias)
- Tratamento de erros: code expirado, ja usado, invalido - mensagens claras
- Script de importacao com modo dry-run e relatorio de erros
- Testes com amostra real anonimizada em ambiente staging

S10 Testes & Auditoria de Seguranca

13 Out 2026 -> 31 Out 2026

! ATENCAO: Seguranca NAO e opcional para produto de R\$18k/comprador.

- Cobertura >= 80% nos services de identidade, pagamento e sessao
- Testes E2E (Playwright): fluxo completo compra -> acesso -> renovacao
- Auditoria OWASP Top 10: XSS, CSRF, rate limiting, enumeracao, injecao
- Teste de carga: 500 webhooks simultaneos sem duplicacao de enrollment
- LGPD: documentar base legal, retencao de dados, responsavel pelo tratamento
- Documentacao completa de variaveis de ambiente e secrets por ambiente

S11 Backup, Ambientes & Go-Live

27 Out 2026 -> 14 Nov 2026

- WAL streaming continuo configurado (RPO <= 5 minutos)
- Snapshot diario com restore testado e documentado (RTO <= 1 hora)
- Runbook de disaster recovery executado em staging
- Checklist go-live: Stripe live keys, DNS, SSL, monitoramento ativo
- Alertas configurados: webhook failure, enrollment error, rate limit hit
- Deploy blue/green em producao
- SLA definido e documentado contratualmente com o cliente produtor

S12 Subscriptions & Grace Period

10 Nov 2026 -> 28 Nov 2026

- Stripe Subscriptions: invoice.payment_succeeded e invoice.payment_failed
- Status grace_period no enrollment com prazo configuravel por curso
- Banner de aviso de renovacao pendente na area do comprador
- Cancelamento e reativacao de subscription via admin e via comprador
- Testes: falha de pagamento -> grace period -> expiracao -> perda de acesso

S13 Chargebacks, Risk Score & Reembolso

24 Nov 2026 -> 12 Dez 2026

- Webhook charge.dispute.created -> revogacao imediata do enrollment
- Tabela risk_signals com score acumulado: +100 chargeback, +200 dispute_lost
- high_risk (score > 100): proxima compra criada como pending_review
- Disputa ganha: risk_score -50, enrollment pode ser reativado
- Politica de reembolso configuravel por curso: janela + % maximo de progresso
- Reembolso automatico ou com aprovacao admin (campo refund_requires_approval)
- Testes: chargeback em serie, score threshold, reembolso automatico e manual

MARCOS PRINCIPAIS (GO/NO-GO)

Marco	Sprint	Nome	Data-limite	Critério de aceite
M1	S02	Checkout Funcional	11 Jul 2026	Pagamento Stripe processado, webhook idempotente, user_token
M2	S04	Identidade Completa	08 Ago 2026	4 sinais + 3 estados + PIN + alias testados, cobertura >= 80%
M3	S06	Acesso a Conteudo	05 Set 2026	Video reproduz com signed URL, progresso salva, auth_level bloq
M4	S08	Admin + Anti-sharing	03 Out 2026	Painel admin funcional, 3o device bloqueado, sessao unica confir
M5	S09	Migracao Validada	17 Out 2026	Claim codes testados com base real (staging), legacy_payments i
M6	S11	GO-LIVE	14 Nov 2026	Sistema em producao, backup testado (restore < 1h), Stripe live k
M7	S13	Pos-Lancamento Completo	12 Dez 2026	Subscriptions + grace period + chargebacks + risk scoring + reem

PRINCIPAIS RISCOS & MITIGACOES

- > **Decisao de plataforma de video atrasada**
Impacto: Bloqueia implementacao completa do Sprint 6 (Player + Signed URLs)
Mitigacao: Decidir Mux vs Bunny Stream no Sprint 1. Critérios: custo por GB, DRM, latencia BR.
- > **Timeline estourar para 30+ semanas**
Impacto: Atraso no go-live, custo maior, cliente insatisfeito
Mitigacao: Revisao de escopo ao fim de cada fase. Remover migracao do MVP se necessario.
- > **Vulnerabilidade no sistema de identidade**
Impacto: Acesso nao autorizado a cursos de R\$18k/ano, dano reputacional severo
Mitigacao: Sprint 10 dedicado a pentest + auditoria OWASP. Nunca pular por prazo.
- > **Chargeback em lote de usuarios high_risk**
Impacto: Perda financeira + risco de conta Stripe suspensa
Mitigacao: Risk scoring no pos-lancamento (Sprint 13). Monitorar alerta de dispute_rate.
- > **Railway sem SLA contratual para producao**
Impacto: Sem garantia de uptime para produto de R\$18k/comprador
Mitigacao: Definir SLA no contrato com o cliente. Avaliar migracao para AWS/GCP se necessario.

STACK TECNICA CONFIRMADA

Frontend	Next.js 14+ App Router - TypeScript - Tailwind CSS
Backend	NestJS - TypeScript - BullMQ (filas de webhook)
Banco	PostgreSQL 16+ - Redis 7+ (rate limiting + sessoes)
Pagamentos	Stripe Checkout - Stripe Subscriptions - Stripe Disputes API
Video	A DEFINIR no Sprint 1: Mux OU Bunny Stream
Hospedagem	Vercel (frontend) - Railway (backend API)
E-mail	Resend (magic links)
Monorepo	Turborepo 2 + npm workspaces
CI/CD	GitHub Actions
Dev local	Docker Compose (PostgreSQL 16 + Redis 7)
Observabilidade	Alertas: webhook failure, enrollment error, rate limit hit (Sentry ou Datadog)

DECISOES ARQUITETURAIS CRITICAS (correcoes ao v6.0 original)

JWT -> Opaque Token

O doc v6.0 armazenava JWT na tabela sessions com is_active BOOLEAN - paradoxo stateless/stateful. Decisao: opaque token (VARCHAR 128 aleatorio) com server-side storage. Permite invalidacao real.

localStorage -> httpOnly Cookie

O doc v6.0 usava localStorage para device_token - vulneravel a XSS. Decisao: httpOnly cookie + SameSite=Strict + Secure. Inacessivel por JavaScript.

4 sinais explicitados

O doc v6.0 referenciava '4 sinais' sem enumera-los claramente. Definicao: (1) email (2) stripe_customer_id (3) card_last4+BIN (4) device_token.

Timeline: 12 -> 22 semanas (MVP)

Estimativa original de 12 semanas e inviavel para o escopo. Revisao realista: 22 semanas de MVP + 4 semanas de pos-lancamento = 26 semanas total.

Payback: 3 -> 12-18 meses

Premissa original assumia 100% de conversao de 'sharers' em pagantes. Revisao: conversao real de 10-20%. Payback conservador de 12-18 meses.

Plataforma de Cursos Online | Plano de Execucao v1.0 | 09 Jun 2026 | Baseado em PDF-ARCH-001 v6.0